

TPM SPI Link Encryption 작업 내용

1. 개요

항목	내용
목적	TPM SPI 버스를 지나는 비밀 데이터와 난수를 암호화해 버스 도청을 막음
브랜치	tpm-spi-encryption (기존 upstream/release-toe28d4757a3)
커밋	기능 7건: e24c12e9, 0186b2d8, 10fddfff, 251d36f4, 48be1c22, 32251aa8 (8e896ae7 보완), 4a17e809 (주석·문서 커밋 제외)

2. 작업 전 상태

- 사용자 공간 tpm2-tools의 암호화 세션은 이미 적용돼 있었음: rootfs/overlay/data FDE 키, OTA 재부팅, VPN PKCS#11 PIN.
- 보호되지 않던 부분:
 1. VPN PSK/PPK 봉인/해제가 평문으로 전송됨
 2. PKCS#11 토큰/키 프로비저닝(tpm2_ptool)에서 토큰 wrapping key가 평문으로 해제됨
 3. 커널의 TPM 트래픽(hwrng GetRandom)이 평문으로 전송됨 (커널 6.6.116에는 세션 기능이 없음)
 4. 일부 키·PIN 생성이 /dev/urandom 직접 읽기로 되어 있었음

3. 변경 내역

3.1 VPN PSK/PPK 봉인/해제 (e24c12e9)

- tpm-seal-secret.sh: tpm2_create를 암호화 HMAC 세션으로 감쌌(입력 비밀 암호화)
- tpm-unseal-secret.sh: 정책 세션을 salted 암호화 세션으로 교체 (해제 응답 암호화)
- 비밀을 stdin으로 전달 (48be1c22)
 - tpm-seal-secret.sh <psk|ppk> -: stdin에서 읽음. 빈 입력은 거부. 기존 인자 방식도 유지
 - SCLI가 이 방식으로 호출 → 비밀이 프로세스 목록(ps)에 보이지 않음
- SCLI에서 비밀을 지우면 TPM에서도 삭제 (4a17e809)
 - 전에는 del psk secret, del ppk 후 저장해도 TPM 핸들(0x81010101/0x81010201)이 남았음
 - 빈 값이면 핸들을 삭제하고, PPK ID를 지울 때도 삭제함
 - PSK는 auth=psk일 때만 TPM에 보관함 (pubkey로 바꾸면 삭제)
 - strongswan, libreswan 모두 적용

3.2 난수 생성 일원화 (0186b2d8)

- 남은 /dev/urandom 직접 사용 3곳을 shiba_get_random으로 교체
 - 동작: 커널 CRNG 시드를 기다린 뒤 OpenSSL FIPS CTR_DRBG로 생성
 - 대상: OTA rootfs LUKS 키(update-rootfs-luks-verity-with-tpm.sh), VPN PIN(vpn-pkcs11-pin.sh), FE salt(fe-lib.sh)

3.3 PKCS#11 프로비저닝 (10fddfff)

- 토큰과 키 생성을 `tpm2_ptool addtoken/addkey` 에서 `pkcs11-tool` (`libtpm2_pkcs11`)로 바꿈. 라이브러리 내부에서 salted+bound HMAC 세션을 씀.
- 기존 동작은 그대로 유지
 - CKA_ID 형식, 키 속성(Usage/Access)이 `ptool`과 같음 → `swan-set-ckaid.sh` 수정 불필요
 - 지원 알고리즘: `ecc256` / `ecc384` / `rsa3072`
- `TPM2_PKCS11_LOG_LEVEL=0` 으로 사용하지 않는 FAPI 경고 제거 (오류 메시지는 유지)

3.4 커널 TPM 세션 백포트 (251d36f4)

결정 사항

- 커널 6.10으로 올리는 대신 **6.6.116에 백포트함**
 - ST BSP가 지원하는 커널은 6.6뿐이고, 6.10은 지원 종료(EOL)된 버전
 - 이 커널 기능은 커널 자신의 TPM 트래픽만 보호함. 우리 시스템에서는 `hwrng`와 `PCR extend`가 대상이고, 사용자 공간 `/dev/tpm*` 경로와는 무관
- 이식 기준은 **linux-6.12.112 (LTS)** + mainline에만 있는 수정
 - 최신 mainline(7.3-rc7)과의 차이는 대부분 6.6에 없는 API로 바꾼 리팩터라서 제외

산출물

- `recipes-kernel/linux/files/6.6/0005-tpm-hmac-sessions.patch` (신규)
- `linux-stm32mp_%.bbappend`: SRC_URI에 패치 추가
- `6.6/fragment-tpm.cfg`: `CONFIG_TCG_TPM2_HMAC=y`

동작 방식

- 부팅 시 TPM null hierarchy에 ECC P-256 primary를 만들고, 그 context와 name을 커널에 저장함 (`/sys/class/tpm/tpm0/null_name`으로 노출)
- 세션 시작
 - null key를 로드하고 ECDH로 salt를 만들어 `StartAuthSession` (HMAC 세션) 실행
 - 세션 설정: AES-128-CFB, SHA-256
- 명령마다 요청 HMAC을 붙이고, 응답 HMAC을 검증하고, 파라미터를 암호화함

명령	보호
<code>TPM2_GetRandom</code> (<code>hwrng</code>)	응답 암호화 + HMAC
<code>TPM2_PCR_Extend</code>	HMAC (모듈 파라미터 <code>disable_pcr_integrity</code> 로 끌 수 있음)

- 세션 수명 (lazy flush)
 - `hwrng` 호출 사이에 세션을 닫지 않고 유지함
 - 사용자 공간 명령, suspend, shutdown, 드라이버 해제 직전에 flush함
- null key 이름이 부팅 후 바뀌면 TPM을 비활성화함 (`TPM_CHIP_FLAG_DISABLE`)

파일별 변경

파일	변경
<code>tpm2-sessions.c</code> (신규)	세션 생성/종료, HMAC 계산·검증, 파라미터 암호화, null primary 생성·검증, 부팅 초기 <code>hmac(sha512)</code> 생성

파일	변경
tpm-buf.c (신규)	tpm_buf를 헤더 inline에서 분리. 길이/핸들 수 추적, TPM2B 버퍼, 읽기 범위 검사
tpm2-cmd.c	GetRandom/PCR_Extend를 세션 경로로 변경, 시작 시 tpm2_sessions_init 호출
tpm-chip.c	DISABLE 플래그 검사, 종료·해제 시 세션 flush, auth 메모리 안전 해제
tpm-dev-common.c	사용자 공간 명령 전에 커널 세션 flush
tpm-interface.c	응답 길이 기록, suspend 시 세션 flush
tpm2-space.c	context load/save를 외부에 공개, TPM2_RC_INTEGRITY 처리
tpm-sysfs.c	null_name 속성 추가
tpm.h, include/linux/tpm.h	세션 구조체·상수·API 선언
lib/crypto/aescfb.c (신규) + Kconfig/Makefile, include/crypto/aes.h	AES-CFB 라이브러리
drivers/char/tpm/Kconfig, Makefile	TCG_TPM2_HMAC 추가. 선택 시 ECDH, AESCFB, SHA256, UTILS를 함께 컴 (ECDH는 m → y로 바뀜)

6.12.112 위에 mainline에서 추가로 가져온 수정

1. read_public: 지원하지 않는 name 알고리즘을 거부 (음수 크기가 그대로 쓰이던 문제)
2. load_null: null key 불일치 시 -ENODEV를 반환하고 TPM 비활성화 (6.12.112에는 초기화 안 된 핸들을 그대로 쓰는 버그가 있음)
3. get_random: lazy flush 적용 (6.12.y는 호출마다 세션을 닫음)
4. get_random: 응답 길이를 실제 파라미터 위치 기준으로 검사

제외한 항목

- tpm_buf 용량/힙 할당 리팩터, allocated_banks 배열화, tpm_send() 제거, no_llseek 정리
- trusted keys 세션 지원 (CONFIG_TRUSTED_KEYS가 꺼져 있음)

부팅 경고 수정 (8e896ae7 → 32251aa8)

- 증상: 부팅 시 TPM probe에서 커널 WARNING 1건 (kmod.c:144 __request_module), 커널 taint 표시
- 원인
 - 첫 세션의 ECDH 키를 만들 때 커널 기본 DRBG가 처음 초기화되면서 hmac(sha512) 인스턴스를 만들
 - 이 커널은 암호 자체 시험이 꺼져 있어서(CRYPTO_MANAGER_DISABLE_TESTS=y) 이 시점에 처음 만들어지고, 이때 request_module()을 호출함
 - TPM SPI 드라이버는 비동기로 probe하는데, 비동기 컨텍스트에서 모듈 로드를 요청하면 커널이 경고함
 - mainline도 같은 코드라서 같은 조건이면 재현됨
- 1차 수정(8e896ae7): TPM probe 전에 기본 RNG를 미리 만들 → 경고는 없어졌지만, 모듈 로드 요청이 initramfs 압축 해제를 기다리느라 커널 부팅이 약 2.3초 늘어남
- 최종 수정(32251aa8): tpm2-sessions.c의 device_initcall에서 hmac(sha512) 만 CRYPTO_NOLOAD로 미리 만들
 - 모듈 로드를 요청하지 않으므로 기다리는 시간이 없음
 - DRBG 시드는 원래처럼 TPM probe 때 jitterentropy와 함께 이루어짐
 - 커널이 TPM을 모듈로 빌드할 때는 넣지 않음 (#ifndef MODULE)

빌드: 컴파일 경고 0건. 레이어 패치만으로 이미지 빌드가 되는 것까지 확인.

4. 디바이스 검증

항목	결과
커널 설정	CONFIG_TCG_TPM2_HMAC=y, ECDH/AESCFB 빌트인
null_name	000b... (SHA-256 name) 값이 채워져 있음 → 부팅 시 null primary 생성·검증 성공
hwrng 세션 사용	kprobe로 명령마다 HMAC 계산·검증 확인, lazy flush 동작 확인
dmesg	HMAC/null key 오류 없음
성능	GetRandom(32B) 명령당 약 24 ms (세션 없을 때 약 9 ms). 유틸 시 30초에 1회라 영향 무시 가능
부팅 경고	WARNING 0건, 커널 taint는 외부 모듈 표시만 남음. TPM probe 시점이 수정 전과 같음 (약 4.3초)
OTA	grey(base → factory-grey → ota-grey), red(base → red → red, 양쪽 bank)에서 rootfs 키와 FDE 게이트 재봉인 후 부팅 정상
FDE	red: overlay·data 프로비저닝(공유 게이트 봉인 → unseal 확인) 정상. grey: overlay KEK 봉인·unseal 정상
VPN	EST 등록 → PKCS#11 토큰에 P-384 키 생성 → strongswan으로 Cisco ASA 연결
PSK/PPK	SCLI로 설정 시 stdin 전달 확인, 봉인/해제 값 일치. 지우면 TPM 핸들 삭제
회귀	부팅 rootfs/FDE 키 해제, VPN PIN 정상. PPK 봉인/해제 양복 일치 (hwrng 동시 부하 상태에서 시험)

5. 작업 후 TPM SPI Link Encryption 적용 범위

구분	대상 (스크립트/모듈)	보호	비고
커널	hwrng TPM2_GetRandom	응답 암호화 + HMAC	이번 작업 (커널 백포트)
커널	TPM2_PCR_Extend	HMAC	이번 작업. 현재 커널에서 호출하는 곳 없음 (IMA 미사용)
사용자 공간	rootfs LUKS 키 해제 (init-dmccrypt.sh, initramfs)	응답 암호화	기존
사용자 공간	overlay·data FDE·FE 키 봉인/해제 (fde-kek-lib.sh, initramfs init-fde.sh, fe-lib.sh)	입력/응답 암호화	기존
사용자 공간	OTA rootfs 새 키 봉인·재봉인 (pcr-predict-reseal.sh)	입력/응답 암호화	기존
사용자 공간	VPN PKCS#11 PIN (vpn-pkcs11-pin.sh)	입력/응답 암호화	기존

구분	대상 (스크립트/모듈)	보호	비고
사용자 공간	VPN PSK/PPK (tpm-seal-secret.sh, tpm-unseal-secret.sh)	입력/응답 암호화	이번 작업 (비밀은 stdin으로 전달)
PKCS#11	토큰/키 프로비저닝 (pkcs11-functions.inc)	libtpm2_pkcs11 세션	이번 작업 (tpm2_ptool 대체)
PKCS#11	VPN 인증 서명 등 런타임 사용 (libtpm2_pkcs11)	libtpm2_pkcs11 세션	기존

암호화하지 않는 TPM 트래픽:

- 비밀이 실리지 않는 명령: PCR 읽기, 핸들/속성 조회, 공개키 조회, NV 카운터 등
- 부트로더(TF-A, U-Boot)의 PCR extend (6장 참조)

6. 제한 사항

- 수동 도청만 막음. 능동 인터포저까지 막으려면 EK 인증서로 세션 키를 검증해야 하는데 구현돼 있지 않음.
- 커널 세션 암호(ECDH P-256, AES-128-CFB, HMAC-SHA-256)는 OpenSSL FIPS 경계 밖. 전송 보호용이고 키 생성에는 쓰이지 않음.
- 부트로더(TF-A, U-Boot)의 PCR extend는 적용 범위 밖.